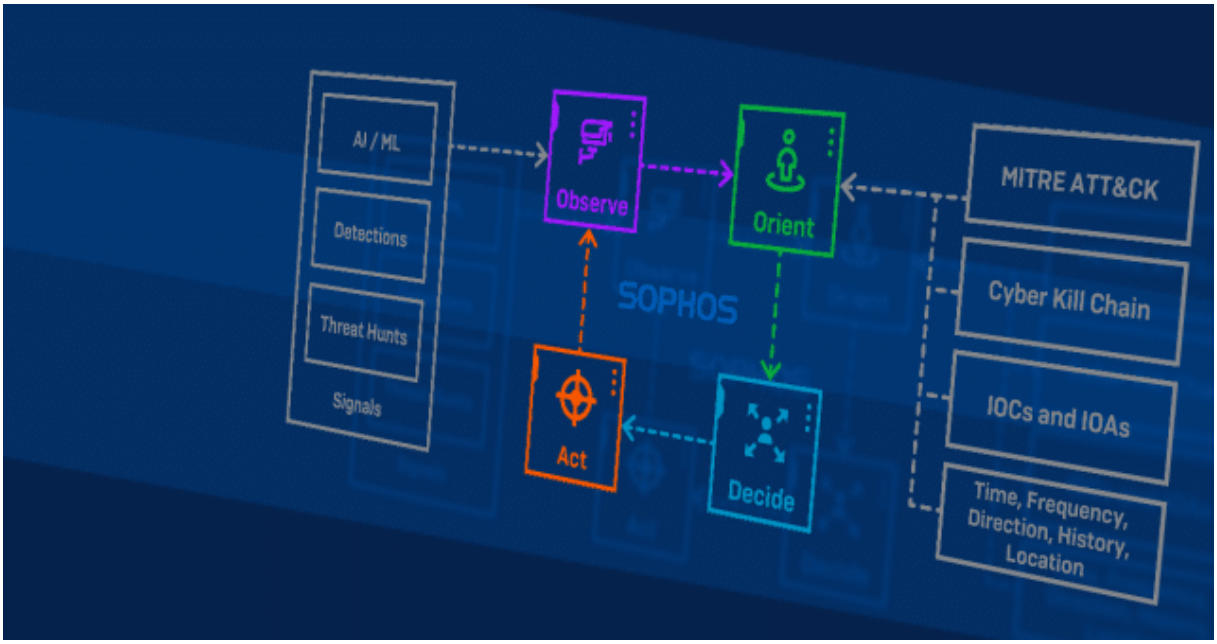


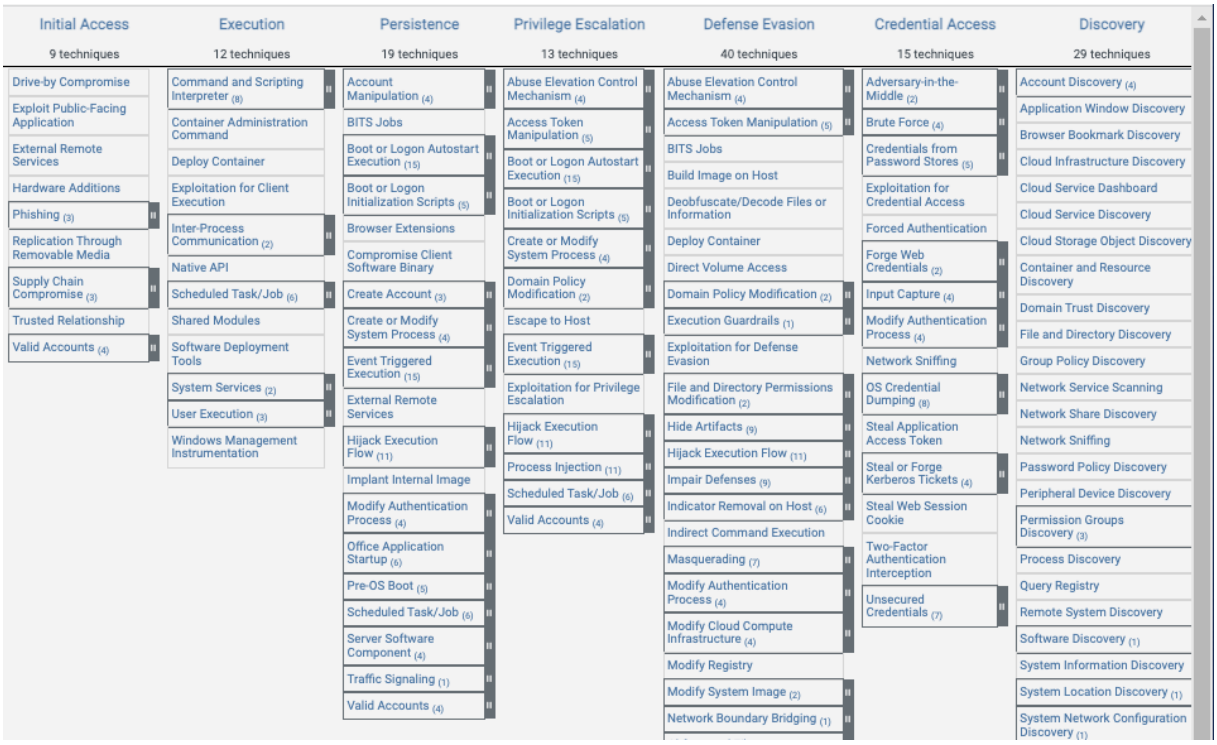
MITRE ATTACK SOPHOS EDR Lab

A- EXPLICATION

C’est quoi Mitre Att&ck

MITRE ATT&CK est un framework, un référentiel de comportements de cyberattaques basé sur des observations concrètes d’activités adverses, classées par tactiques et techniques. C’est une base de connaissances qui regroupe des informations sur les différents types d’attaques observés aujourd’hui. Elle fournit une documentation complète sur les tactiques (objectifs), les techniques et les procédures couramment utilisées par les cybercriminels lors de leurs attaques.

Le framework décrit les comportements adverses spécifiques aux environnements Windows, MacOs, Linux, Cloud et mobiles. Cela permet aux entreprises de mieux se protéger en s’appuyant sur ces informations, et aux professionnels de la cybersécurité de mieux analyser les attaques et les modes opératoires afin d’évaluer les risques. Les attaquants évoluent, mais les méthodes et procédures d’attaque changent peu. Recenser ces techniques permet donc de réduire significativement les risques et les impacts sur les systèmes d’information.



C’est sur ce principe que repose MITRE ATT&CK.

À travers cette image, on peut voir différentes tactiques telles que : ***Initial Access***

Execution, Persistence, Privilege Escalation, Defense Evasion ,Credential Access, Discovery.

Chaque tactique regroupe plusieurs techniques. Ce framework est utilisé par de nombreuses solutions de cybersécurité comme référence pour protéger les ressources des entreprises. C'est notamment le cas de Sophos, qui s'appuie sur MITRE ATT&CK pour proposer des solutions de surveillance et de protection des systèmes.

Sophos est une solution de cybersécurité qui propose des outils de détection et de réponse, des pares-feux, des solutions cloud ainsi que des services gérés pour la sécurité des réseaux et la gestion des menaces.

Il offre une protection contre les logiciels malveillants, les sites de phishing et les ransomwares. Il s'appuie sur une base de données mondiale pour bloquer les accès à des sites malveillants et empêcher les attaques visant des systèmes spécifiques.

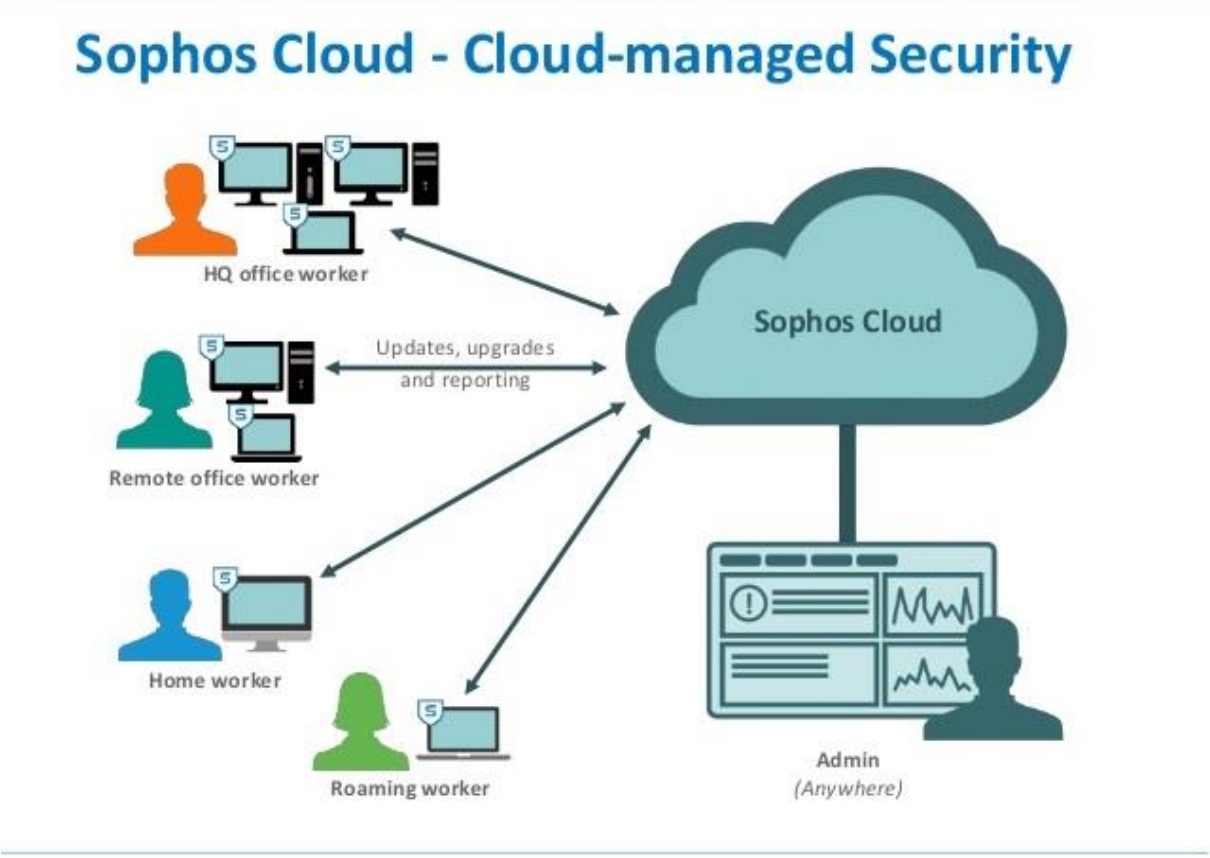
Sophos utilise également les tactiques, techniques et procédures décrites dans le framework MITRE ATT&CK pour améliorer la détection et la réponse aux menaces à travers ses agents.

Avec sa solution EDR (Sophos EDR) :

- Les menaces inconnues sont bloquées
- Les données des entreprises sont protégées contre les ransomwares
- Les Exploits sont bloqués grâces à **Intercept X** qui utilise une technologie anti-exploit
- Les piratages sont empêchés

Sophos est une solution basée sur le cloud qui communique étroitement avec ses agents pour protéger les réseaux, les terminaux et les serveurs. Le rôle de ces agents est d'établir une connexion avec la base centrale et de synchroniser automatiquement les données entre les terminaux, les serveurs et la plateforme Sophos. Lorsqu'une menace est détectée, une décision automatique est prise en s'appuyant sur des échantillons d'attaques, une base de données mondiale de menaces et le framework MITRE ATT&CK.

Ci-dessous, un schéma illustre le fonctionnement de Sophos et la manière dont il communique avec les différents actifs qu'il protège.



Comment déployer Sophos (Sophos EDR)

Pour déployer Sophos EDR et protéger les terminaux, il suffit de se procurer une licence via ce lien

Ensuite, on télécharge l'agent depuis le tableau de bord et on l'installe sur la machine à protéger. Une fois l'installation terminée, l'ordinateur est protégé. À partir de là, les menaces sont détectées et traitées automatiquement, et les alertes sont envoyées vers la plateforme **Sophos Central** pour administration.

Il est également possible de créer des règles personnalisées et de les synchroniser avec les agents.

A. PRATIQUE

Dans notre cas, nous déployons la solution **Sophos EDR** afin de protéger la machine sur laquelle l'agent est installé contre certaines techniques répertoriées par MITRE ATT&CK.

Pour mettre en place ce lab, nous avons besoin de :

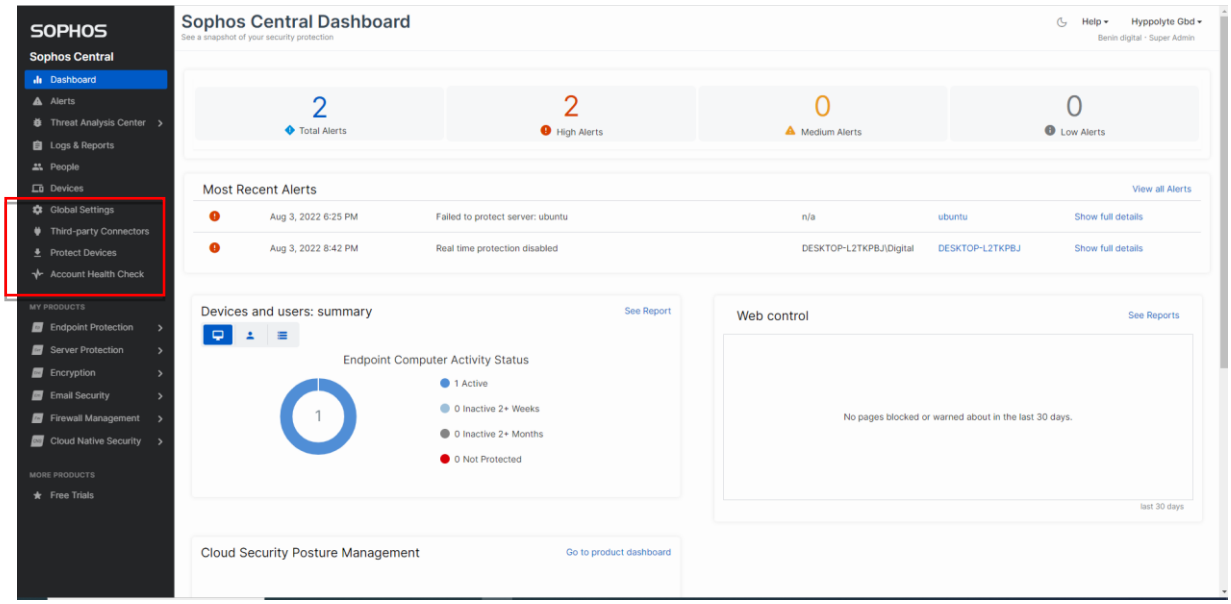
- Un abonnement Sophos (dans notre cas, une période d'essai)
- L'agent XDR de Sophos (Intercept X et EDR), utilisé pour protéger les terminaux
- Un simulateur d'attaques (**CALDERA**), développé par MITRE ATT&CK

Nous travaillons dans un environnement virtualisé avec :

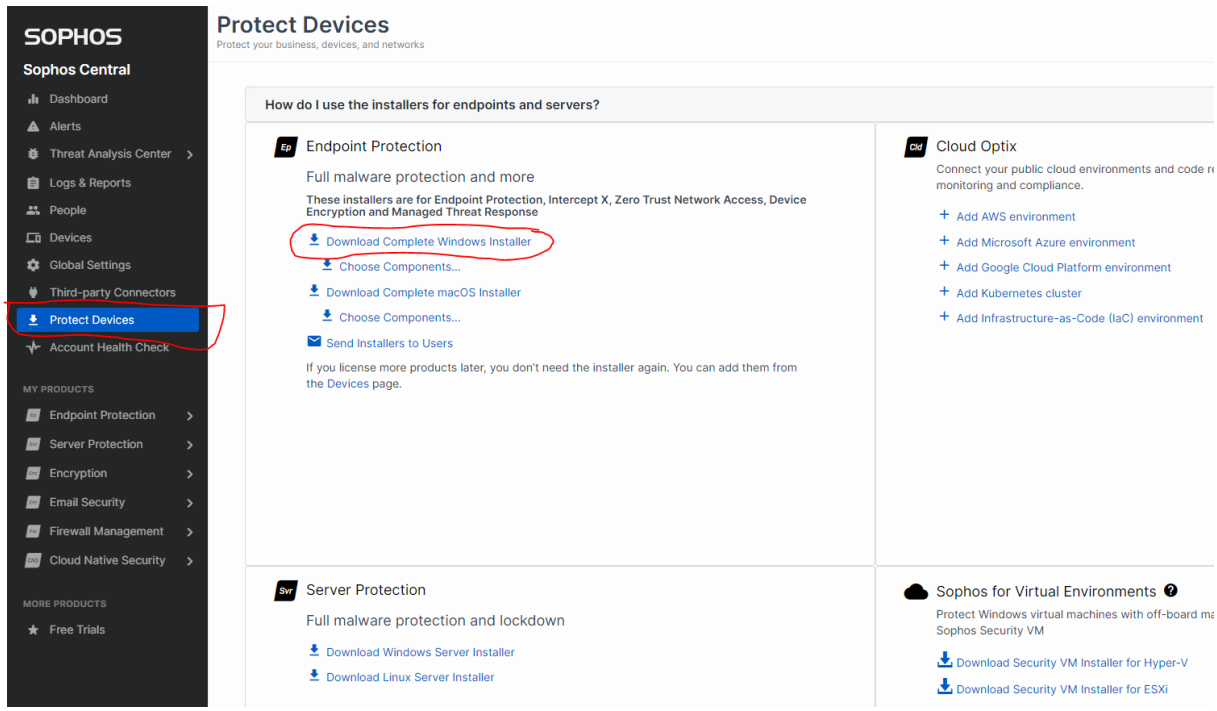
- Une machine Windows (sur laquelle l'agent est installé)
- Une machine Linux (sur laquelle CALDERA est déployé et utilisée pour attaquer la machine cible)

Nous pouvons obtenir une période d'essai via ce lien.

Après connexion au tableau de bord, on obtient un aperçu qui résume l'état des actifs, avec les alertes et autres informations, comme on peut le voir sur l'image suivante.

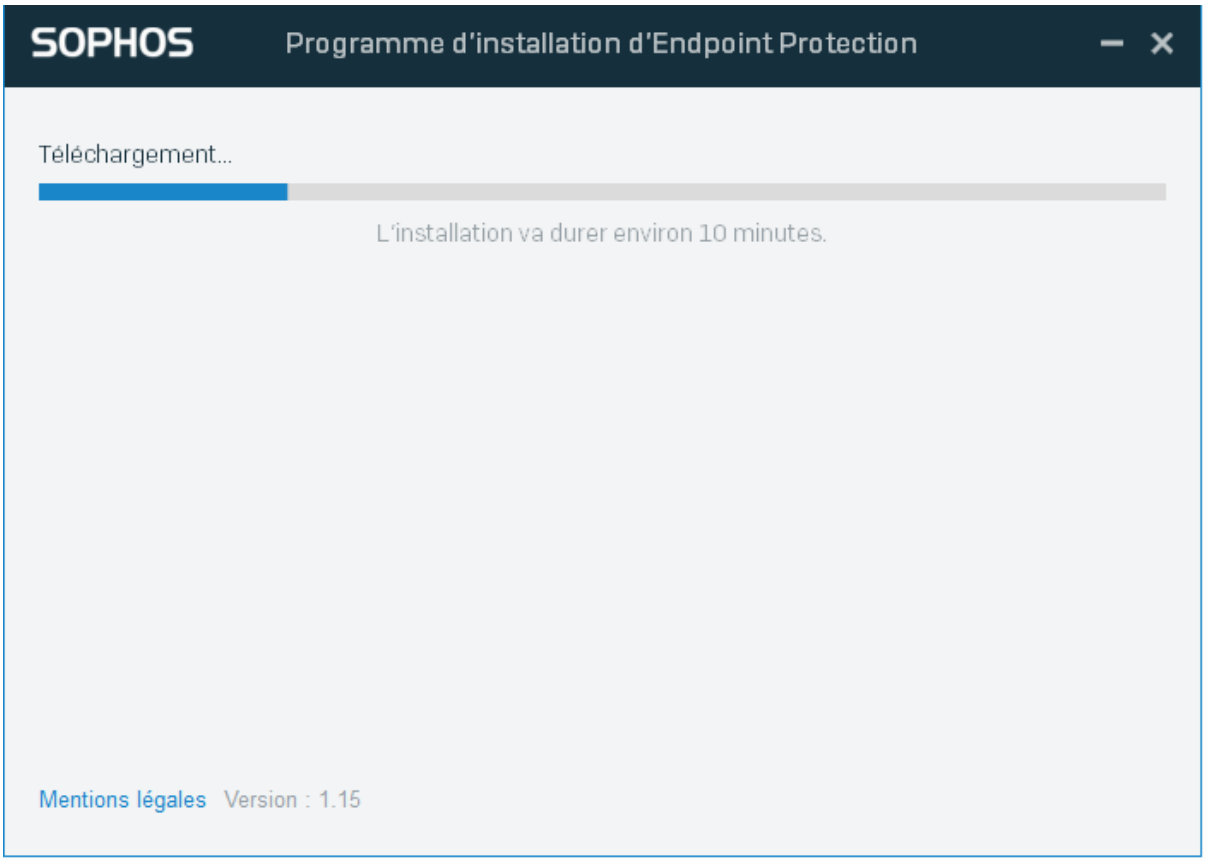


Pour obtenir l'agent à utiliser pour protéger la machine, on se rend dans **Protect Devices**, situé dans le menu du tableau de bord.



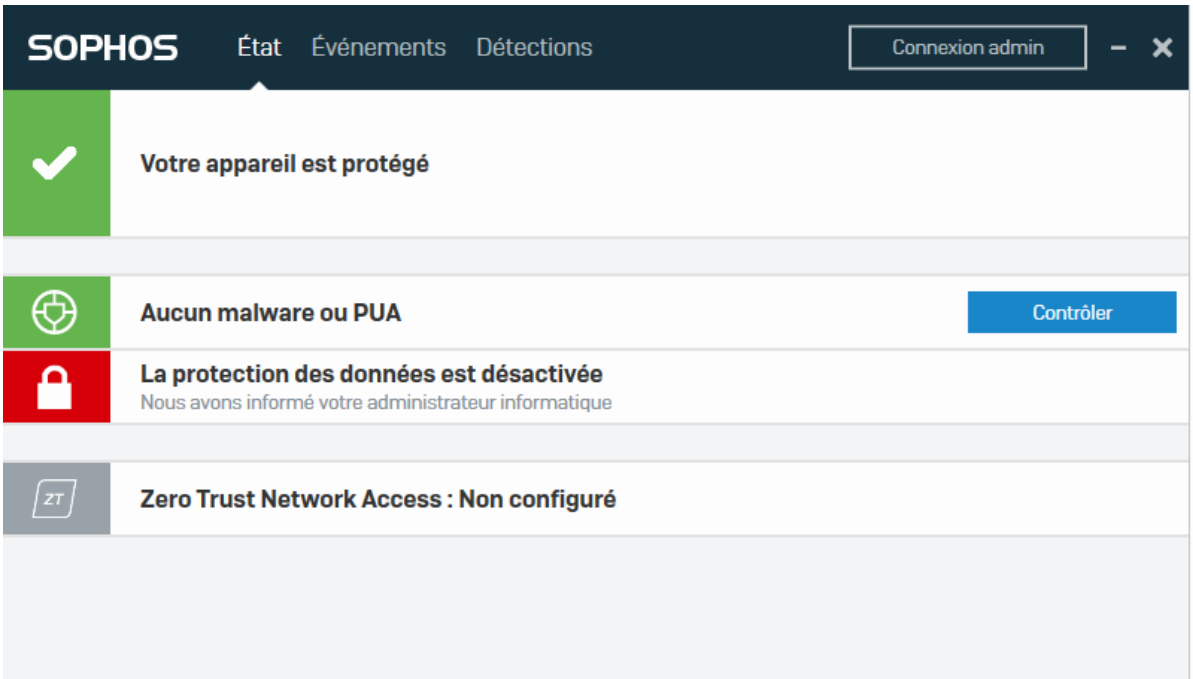
Nous téléchargeons la version Windows dans notre cas. Le lien est disponible ici. Après téléchargement, on se rend sur la machine cible pour lancer l'installation. Le programme s'installe comme tout logiciel standard sous Windows : il suffit de suivre les étapes de l'assistant.

SOPHOS
Programme d'installation d'Endpoint Protection
Vous allez installer les produits suivants.
l'installation va durer environ 10 minutes. Une fois démarrée, elle ne peut plus être annulée.
Device Encryption
Gestion du Chiffrement de lecteur BitLocker et récupération sécurisée.
Intercept X Advanced with XDR
Protection contre les malwares, Exploits, menaces Web et ransomwares, plus analyse des menaces avancées.
Remarque : ce programme d'installation va désinstaller les logiciels de sécurité tiers.
Zero Trust Network Access
Protection de vos ressources avec le contrôle d'accès Zero Trust.
Mentions légales
Version : 1.15
Installer
Annuler


SOPHOS
Programme d'installation d'Endpoint Protection
Téléchargement...
L'installation va durer environ 10 minutes.
Mentions légales
Version : 1.15

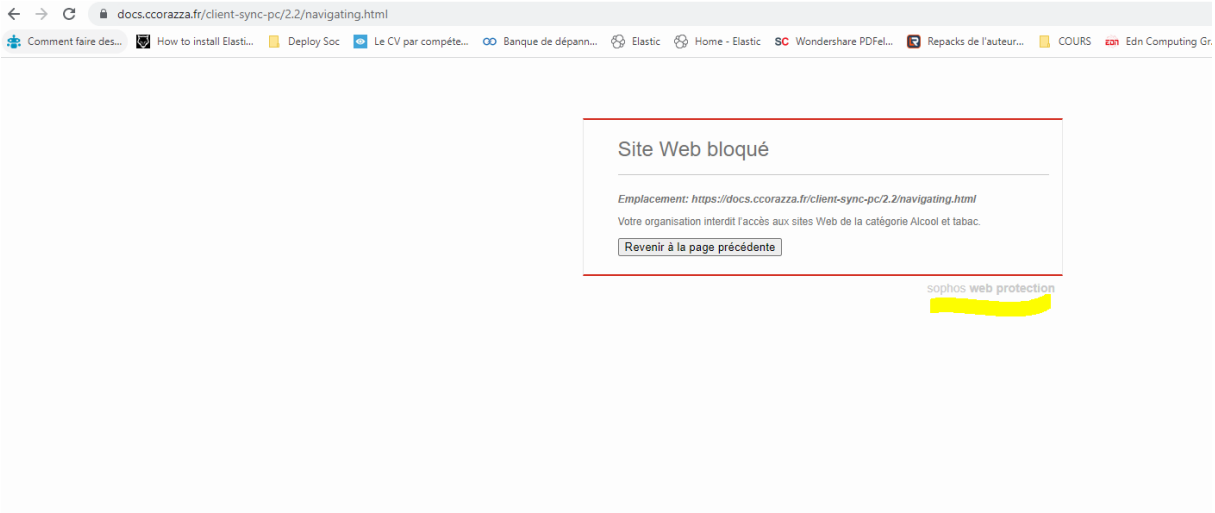
Pendant l'installation, le programme se charge automatiquement d'établir la connexion entre **Sophos Central** et la machine. Il n'y a donc aucune configuration supplémentaire à effectuer.

À la fin de l'installation, tout devient opérationnel. On peut le constater en lançant l'application, où il est indiqué que l'ordinateur est protégé.

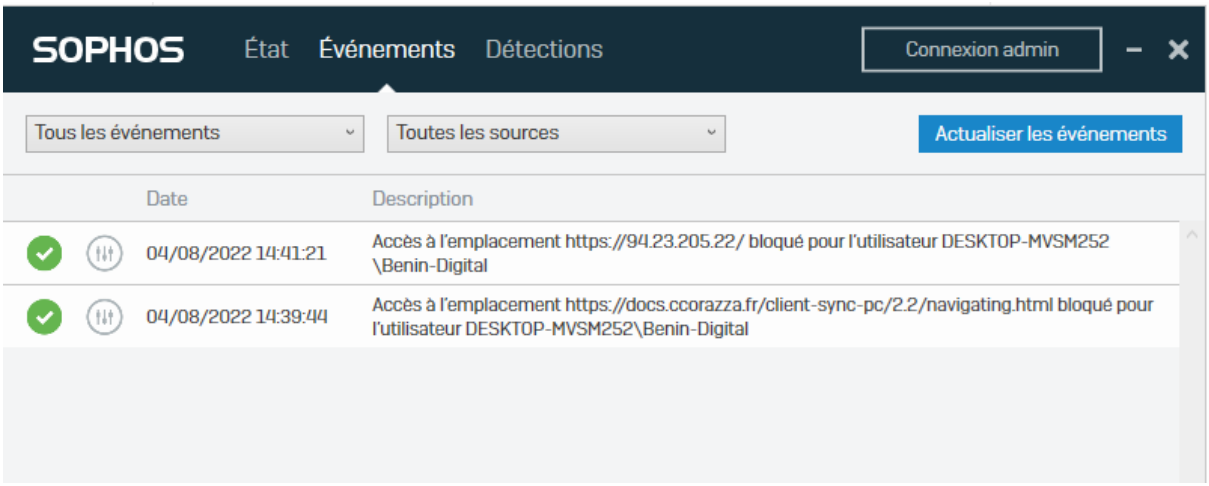


Par défaut, Sophos EDR utilise une base de données préconfigurée pour protéger les terminaux. Certaines attaques ainsi que des sites de phishing sont donc bloqués automatiquement.

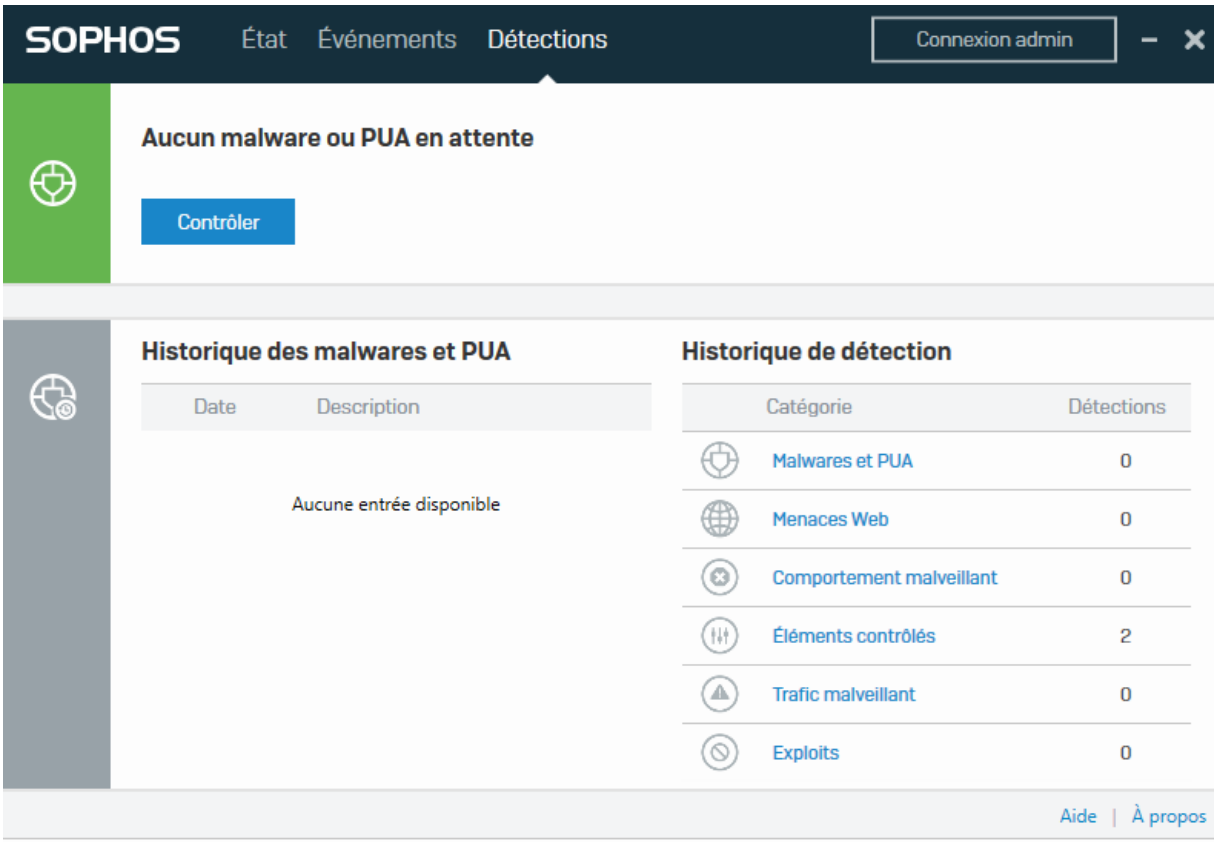
Le phishing est une technique associée à la tactique **Reconnaissance** dans le framework MITRE ATT&CK. En essayant d'accéder à un site de phishing, on constate que l'accès est automatiquement bloqué par la solution Sophos.



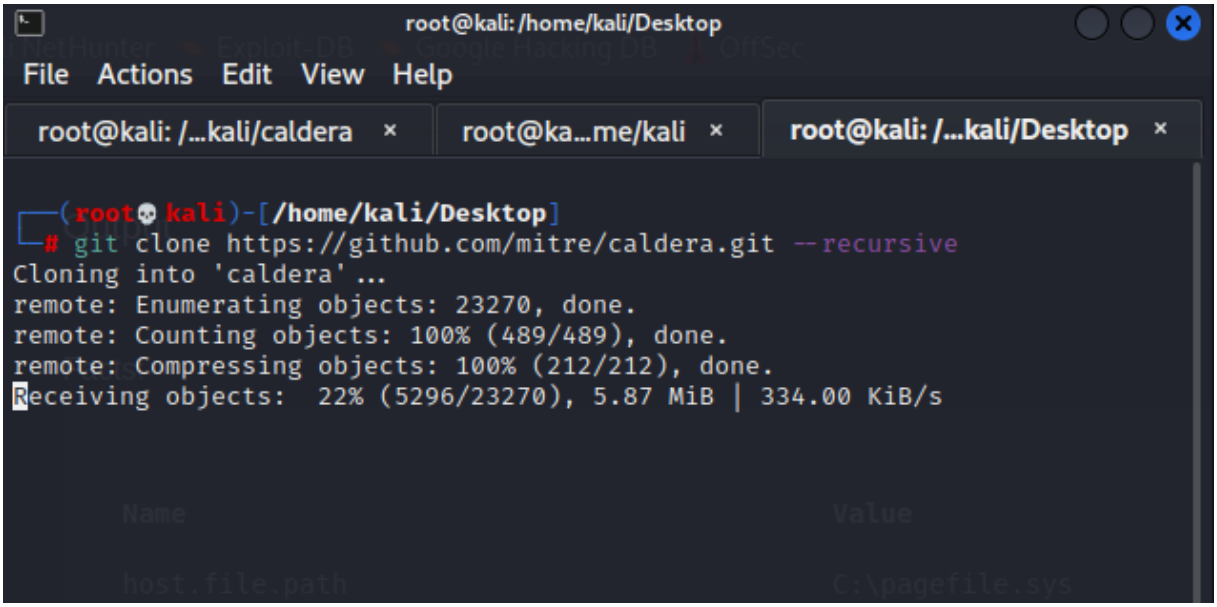
En jaune sur l'image, on peut voir la mention **"Sophos Web Protection"**. En consultant l'application, on a la confirmation que le site est bien bloqué par Sophos.



Dans l'onglet **Événements** de l'application, toutes les activités sont listées. Dans l'onglet **Détection**, on retrouve des statistiques.



Nous allons maintenant simuler certaines tactiques et techniques répertoriées par MITRE ATT&CK en utilisant le simulateur **CALDERA**. Il peut être obtenu via ce lien GitHub. La première étape consiste à le cloner de manière récursive. Une fois le clonage terminé, on passe à son exécution sur la machine. Dans notre cas, nous utilisons une machine Kali Linux.



Nous allons maintenant exécuter le framework. Avant cela, il faut s'assurer que la machine qui héberge le logiciel remplit les conditions suivantes :

- Un système Linux ou macOS avec Python 3.7+ installé (avec pip3)
- Au moins 8 Go d'espace disque et 2 Go de RAM
- GoLang 1.17+ pour compiler dynamiquement les agents basés sur Go

Si toutes ces conditions sont remplies, on peut commencer l'exécution en suivant les instructions disponibles sur le dépôt GitHub.

Dans le répertoire cloné, on exécute la commande indiquée sur l'image suivante afin de récupérer toutes les dépendances nécessaires au bon fonctionnement de l'application.

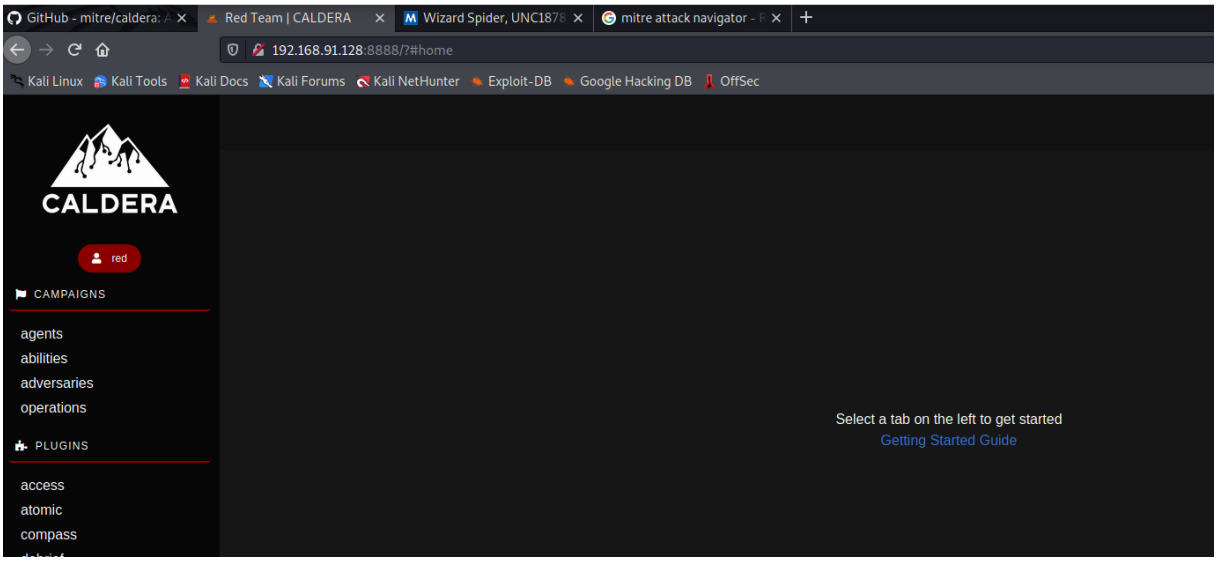
```
┌──(root💀 kali)-[/home/kali/Desktop/caldera]
└─# pip3 install -r requirements.txt
Ignoring cryptography: markers 'python_version ≤ "3.7"' don't match your en
vironment
Ignoring aioftp: markers 'python_version < "3.7"' don't match your environme
nt
Requirement already satisfied: aiohttp-jinja2==1.5.0 in /usr/local/lib/pytho
n3.9/dist-packages (from -r requirements.txt (line 1)) (1.5)
Requirement already satisfied: aiohttp==3.8.1 in /usr/local/lib/python3.9/di
st-packages (from -r requirements.txt (line 2)) (3.8.1)
Requirement already satisfied: aiohttp_session==2.9.0 in /usr/local/lib/pyth
on3.9/dist-packages (from -r requirements.txt (line 3)) (2.9.0)
Requirement already satisfied: aiohttp-security==0.4.0 in /usr/local/lib/pyt
hon3.9/dist-packages (from -r requirements.txt (line 4)) (0.4.0)
Requirement already satisfied: aiohttp-apispec==2.2.3 in /usr/local/lib/pyth
on3.9/dist-packages (from -r requirements.txt (line 5)) (2.2.3)
Requirement already satisfied: jinja2==3.0.3 in /usr/local/lib/python3.9/dis
t-packages (from -r requirements.txt (line 6)) (3.0.3)
Requirement already satisfied: pyyaml ≥ 5.1 in /usr/lib/python3/dist-packages
 (from -r requirements.txt (line 7)) (5.4.1)
Requirement already satisfied: cryptography ≥ 3.2 in /usr/lib/python3/dist-pa
```

On lance ensuite la commande ***python3 server.py --insecure***, toujours dans le répertoire, pour démarrer l'outil.

```
┌──(root💀 kali)-[/home/kali/Desktop/caldera]
└─# python3 server.py --insecure
2022-08-04 09:46:20 - WARNING (server.py:116 <module>) --insecure flag set.
Caldera will use the default.yml config file.
2022-08-04 09:46:20 - INFO  (server.py:123 <module>) Using main config from
conf/default.yml
2022-08-04 09:46:23 - INFO  (contact_gist.py:70 start) Invalid Github Gist p
ersonal API token provided. Gist C2 contact will not be started.
2022-08-04 09:46:23 - ERROR (base_events.py:1738 default_exception_handler)
Task exception was never retrieved
future: <Task finished name='Task-10' coro=<Contact.start() done, defined at
 /home/kali/Desktop/caldera/app/contacts/contact_dns.py:22> exception=OSErro
```

Nous pouvons à présent utiliser l'outil en ouvrant un navigateur et en saisissant l'adresse IP de la machine, suivie du port 8888. Dans notre cas : 192.168.92.128:8888 Une page d'authentification s'affiche.

On utilise **red** comme identifiant et **admin** comme mot de passe. Après authentification, on accède à l'interface suivante.



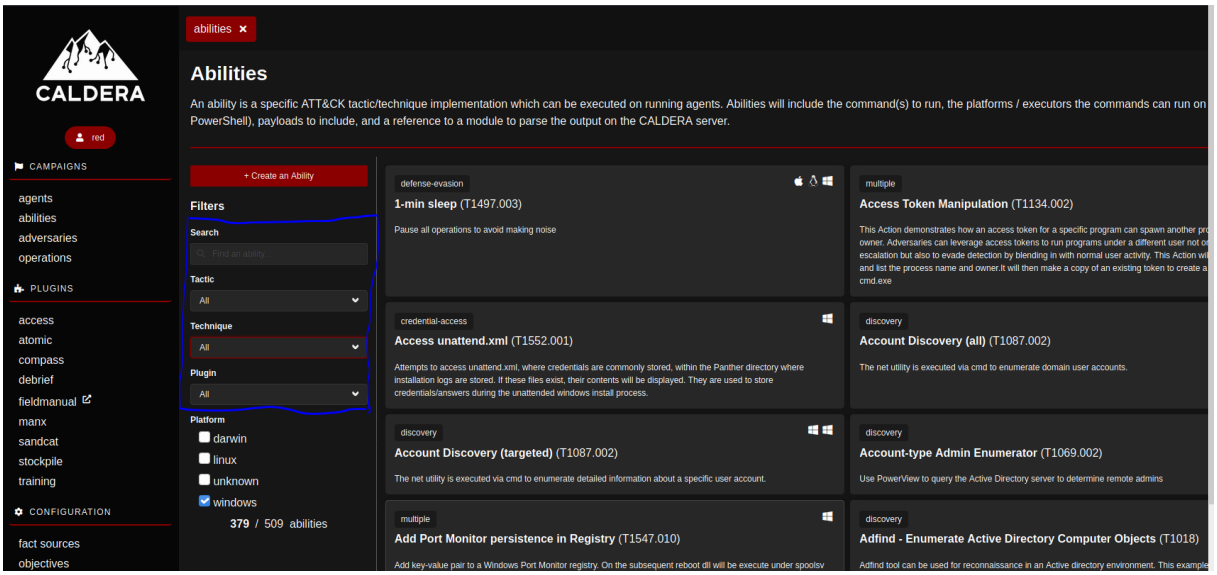
Comment fonctionne l'outil CALDERA

CALDERA utilise des agents pour communiquer avec les machines cibles. Ces agents doivent être déployés sur les machines à tester.

Le fonctionnement est le suivant :

- On déploie un agent sur la machine cible, ce qui permet d'établir une connexion entre les deux machines
- On crée ensuite une opération, dans laquelle on définit les tactiques et techniques à utiliser
- On crée une opération. En créant l'opération, on définit les techniques et tactiques à utiliser. L'opération consiste à simuler des techniques d'attaques Mitre Att&ck sur la cible.

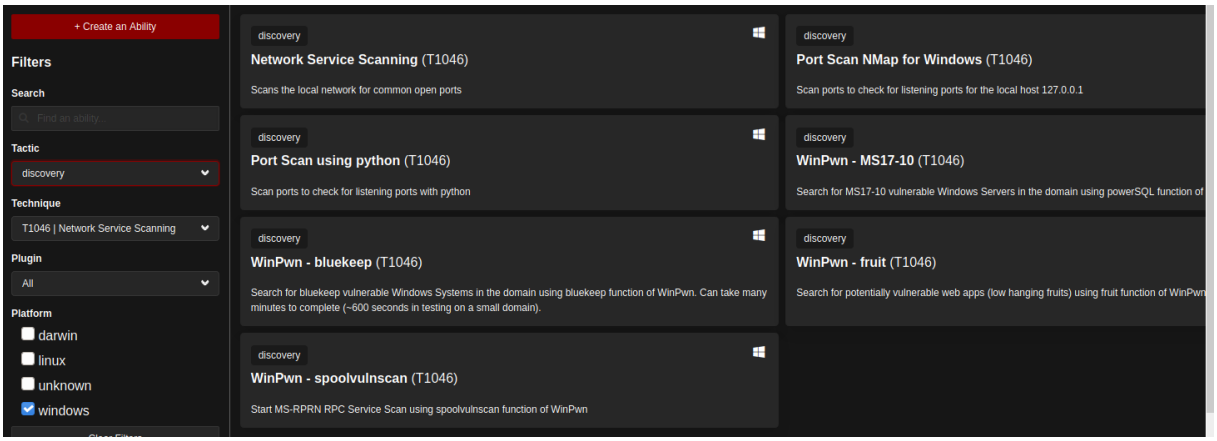
Essayons de créer une **ability** (tactique/technique) sur l'outil pour comprendre son fonctionnement. On se rend dans l'onglet **Ability**, puis on effectue les configurations selon nos besoins.



Dans l'encadré, on définit les tactiques et techniques à utiliser pour l'attaque. Les techniques proposées sont celles définies par **MITRE ATT&CK**. L'outil est donc parfaitement adapté pour simuler des attaques basées sur ce framework.

Dans notre cas, nous choisissons une attaque de type **Discovery (reconnaissance)**, qui utilise la technique de découverte des services réseau actifs sur la cible (**T1046 – Network Service Scanning**).

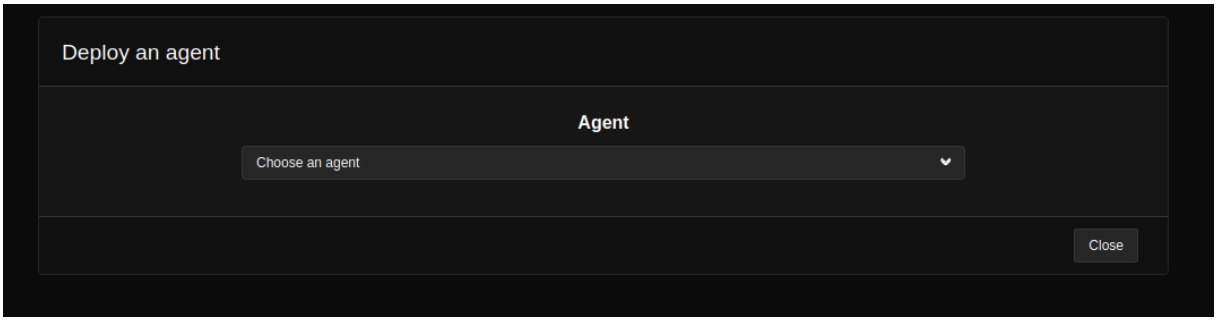
En personnalisant ce choix, différentes tactiques liées à la phase de découverte sont proposées. On sélectionne ensuite celles qui correspondent à nos objectifs.



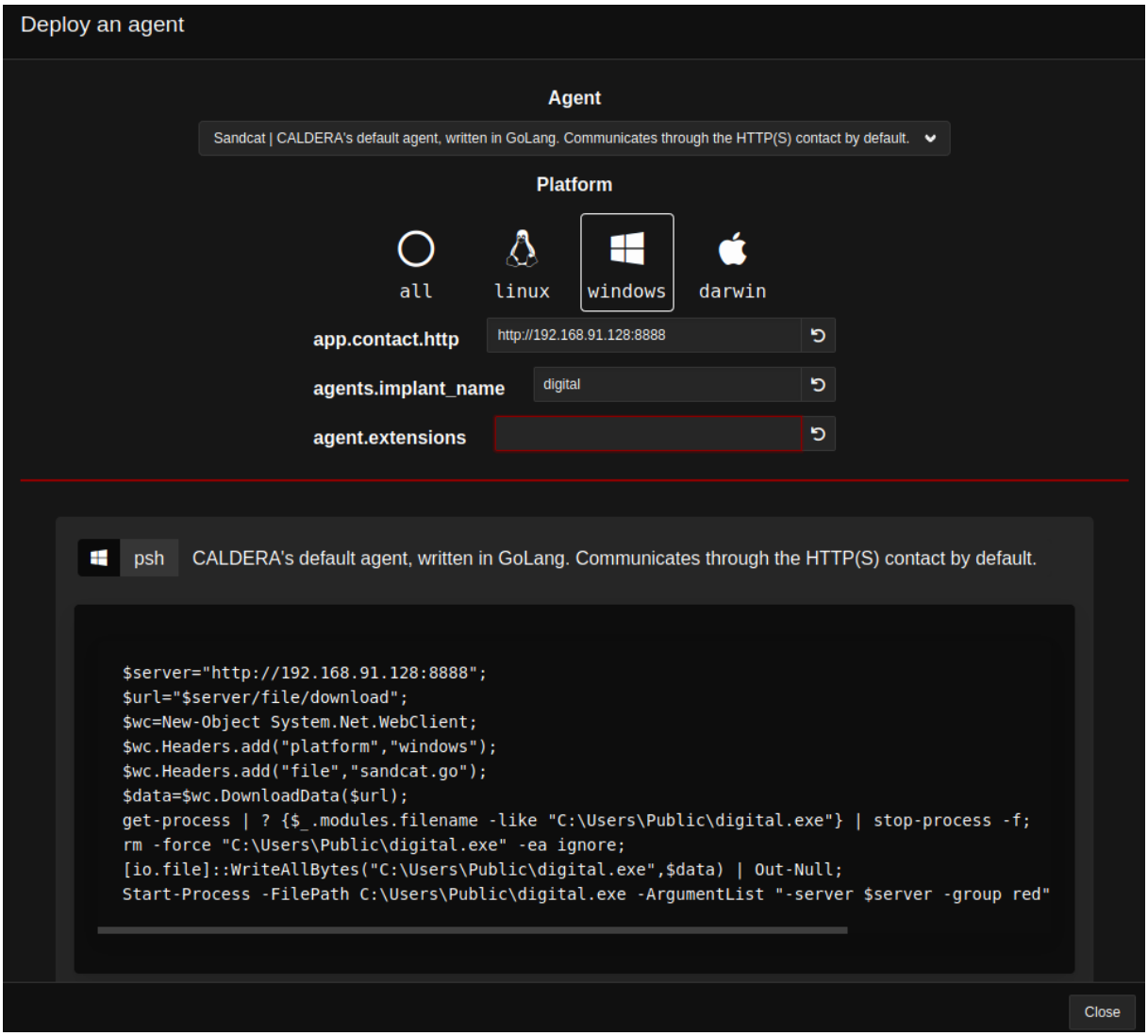
Dans notre cas, nous choisissons par exemple **WinPwn – spoolvulscan**, puis nous suivons les instructions.

Cette ability peut ensuite être utilisée pour créer une opération. Mais avant de lancer des opérations (simulation d'attaques), il faut d'abord créer les agents.

agents. Nous allons enrôler les machines cibles au niveau de caldera. On va dans Agent à gauche dans le menu puis on clique sur **Deploy agent.**



On sélectionne le type d'agent souhaité, de préférence le premier. On accède ensuite à une page qui demande de spécifier le système sur lequel l'agent sera déployé, ainsi que l'adresse du serveur sur lequel **CALDERA** est installé.



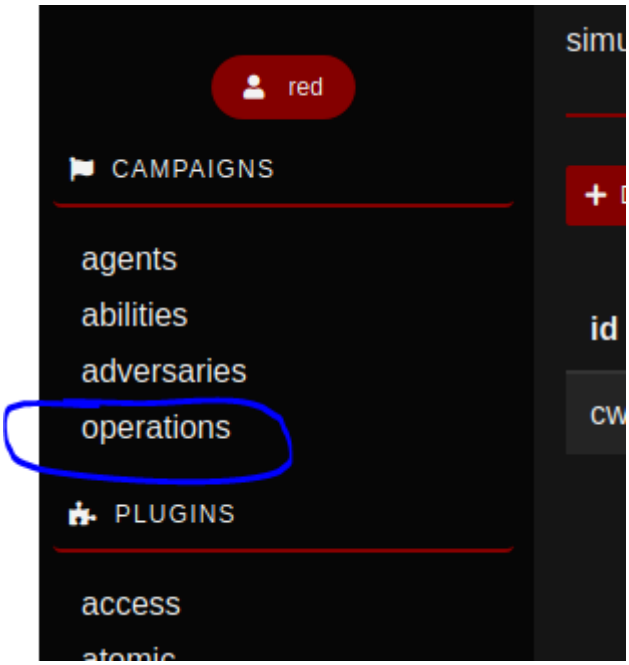
On copie le code généré et on l'exécute sur la machine cible. Il s'agit d'un script à exécuter en **PowerShell**. Une fois exécuté, l'agent est enrôlé, la connexion est établie, et il devient possible d'interagir avec la machine cible en utilisant des tactiques et techniques de **MITRE ATT&CK**.

L'objectif est de détecter ces attaques avec **Sophos EDR**. Après l'exécution du script sur la machine cible, on obtient un retour. Une communication s'établit, et l'ordinateur apparaît dans la liste des agents au niveau de **CALDERA**.

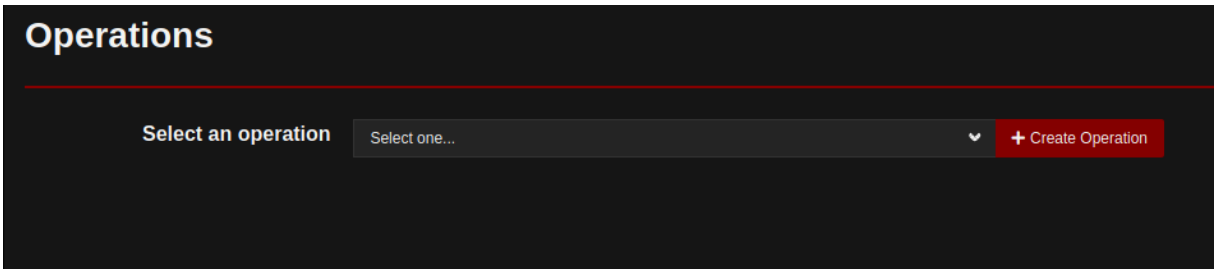
La figure ci-après montre le résultat après le déploiement de l'agent.

id (paw)	host	group	platform	contact	pid	privilege	status	last seen
cwbikq	DESKTOP-L2TKPBJ	red	windows	HTTP	5480	Elevated	alive, trusted	51 seconds ago

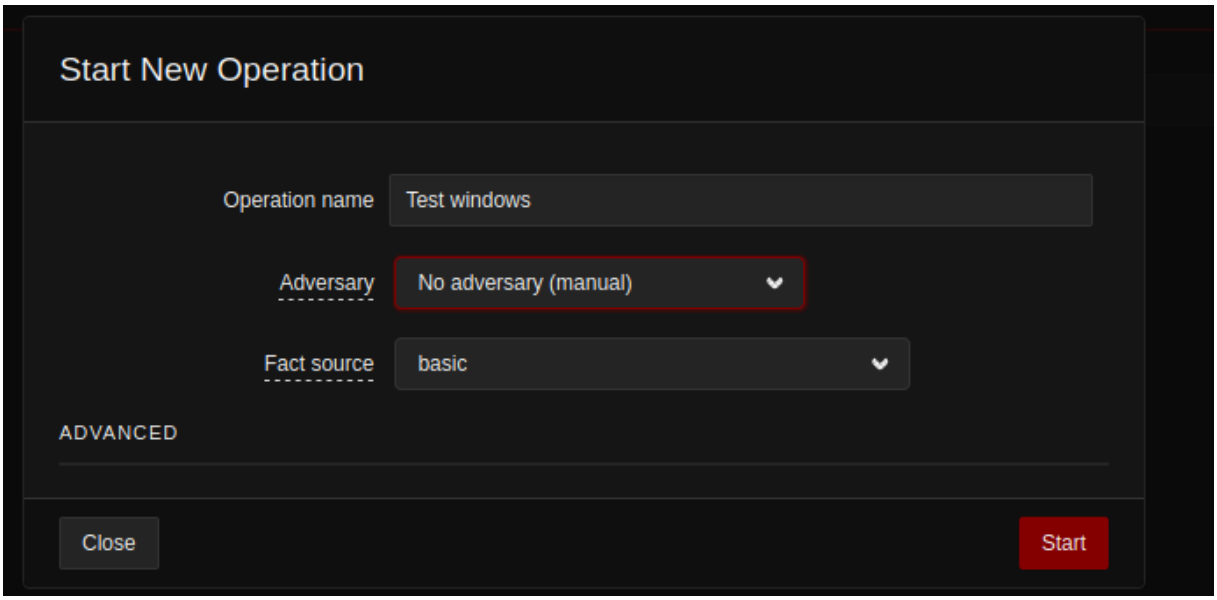
Nous sommes désormais en communication avec la machine cible. L'étape suivante consiste à simuler une technique de **MITRE ATT&CK** sur celle-ci. Pour cela, nous allons créer une opération dans **CALDERA**, puis lancer l'attaque. Dans le menu de CALDERA, on clique sur **Operation**.



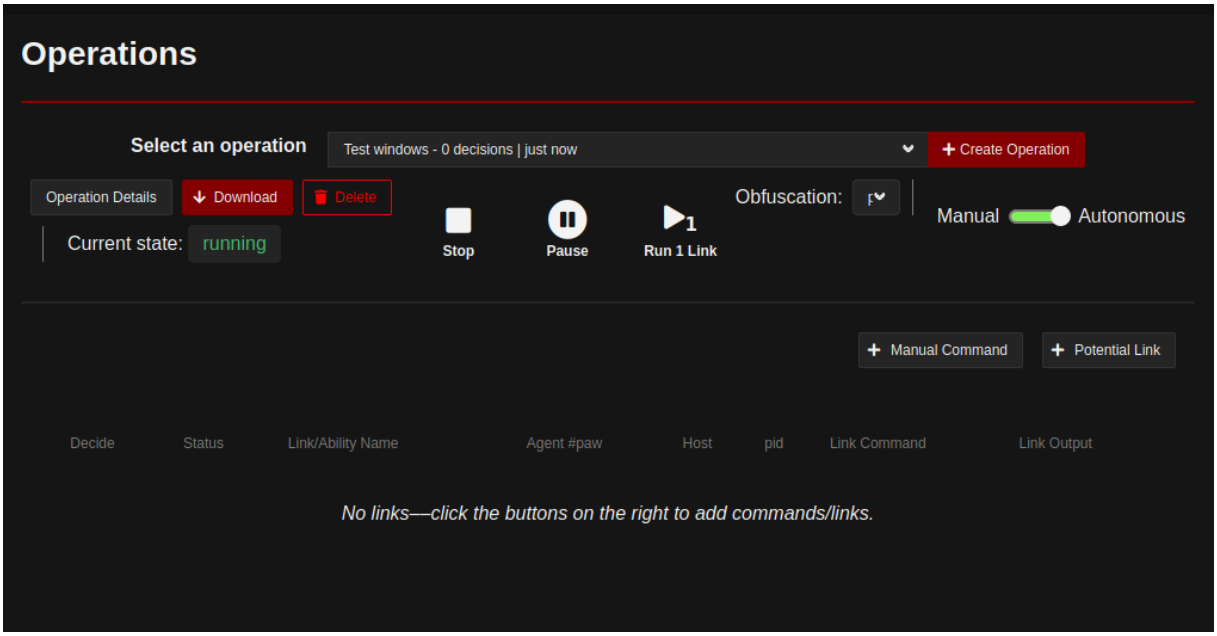
La page qui s'affiche nous demande d'en créer une nouvelle.



On clique sur **create operation** puis on renseigne les informations comme sur la figure suivante.



On laisse l'option **Adversary** sur *Manual*, puis on clique sur **"Start"** pour démarrer. On obtient alors la page suivante.

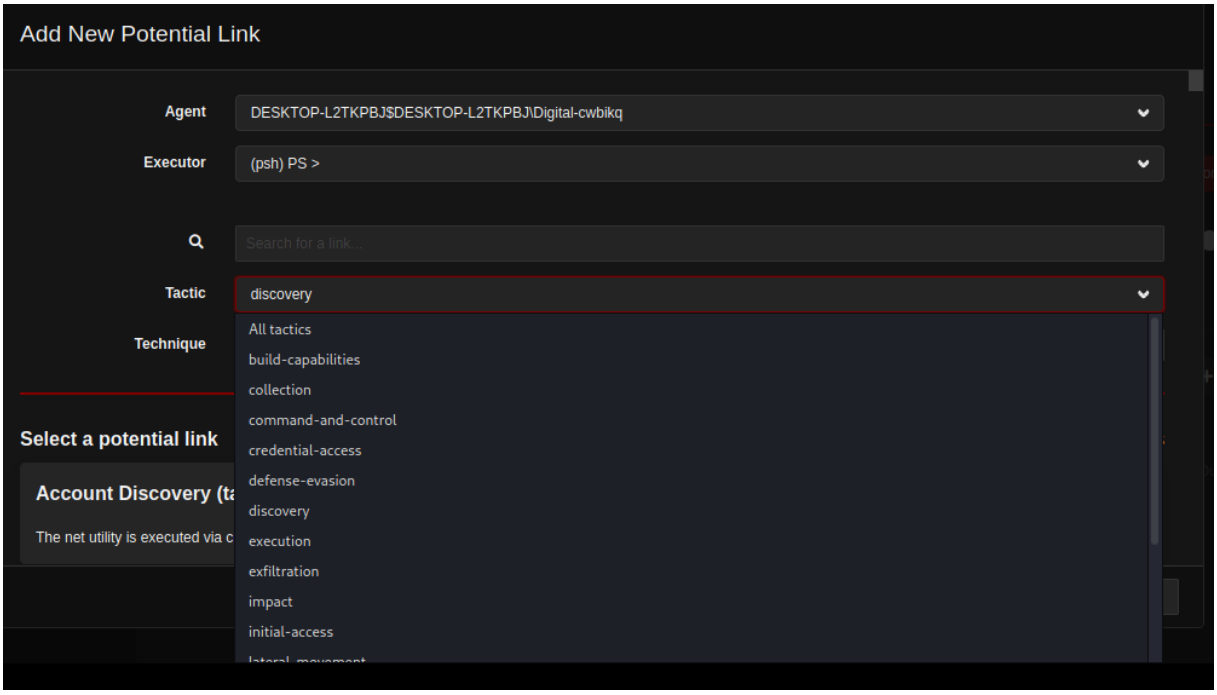


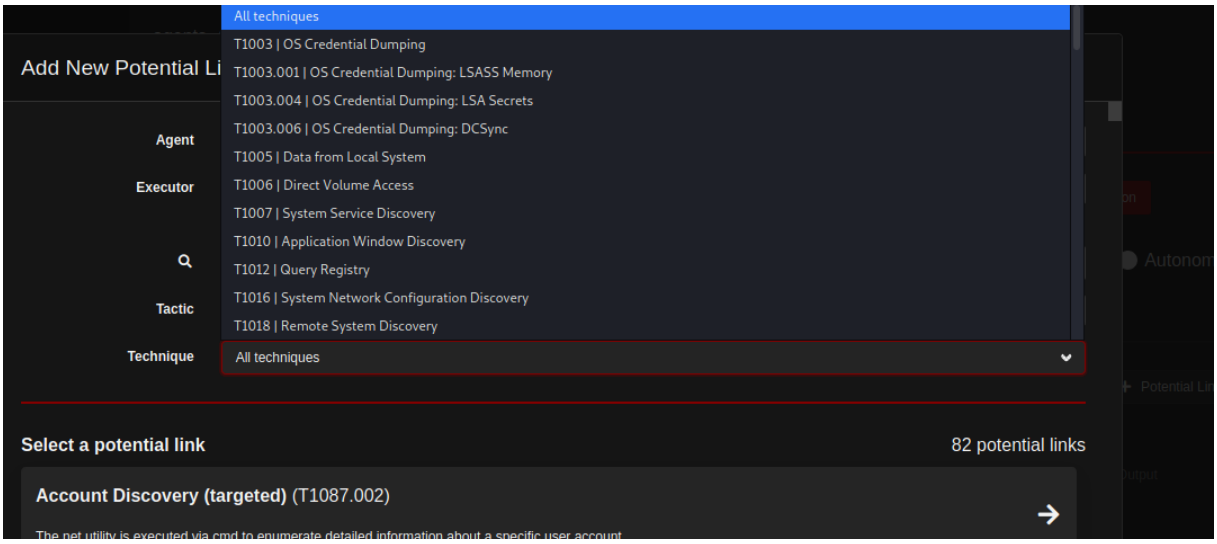
L'opération est lancée, mais rien ne s'exécute. En effet, aucune tâche n'a encore été spécifiée. Il faut définir les tactiques et techniques à utiliser.

On peut lire sur l'interface : *No links — click the buttons on the right to add command/links*.

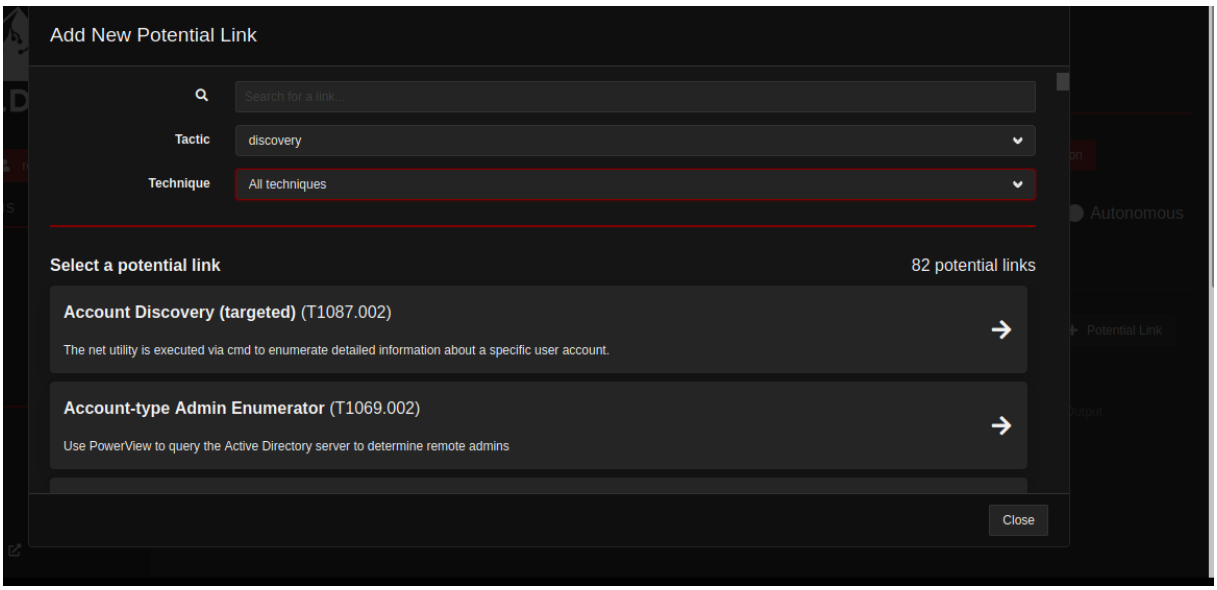
Pour lancer correctement l'attaque, on clique sur **Potential Link**, situé au milieu à droite de l'écran. Cela permet de choisir les tactiques et techniques à utiliser.

On accède ensuite à une page qui demande de renseigner nos préférences.

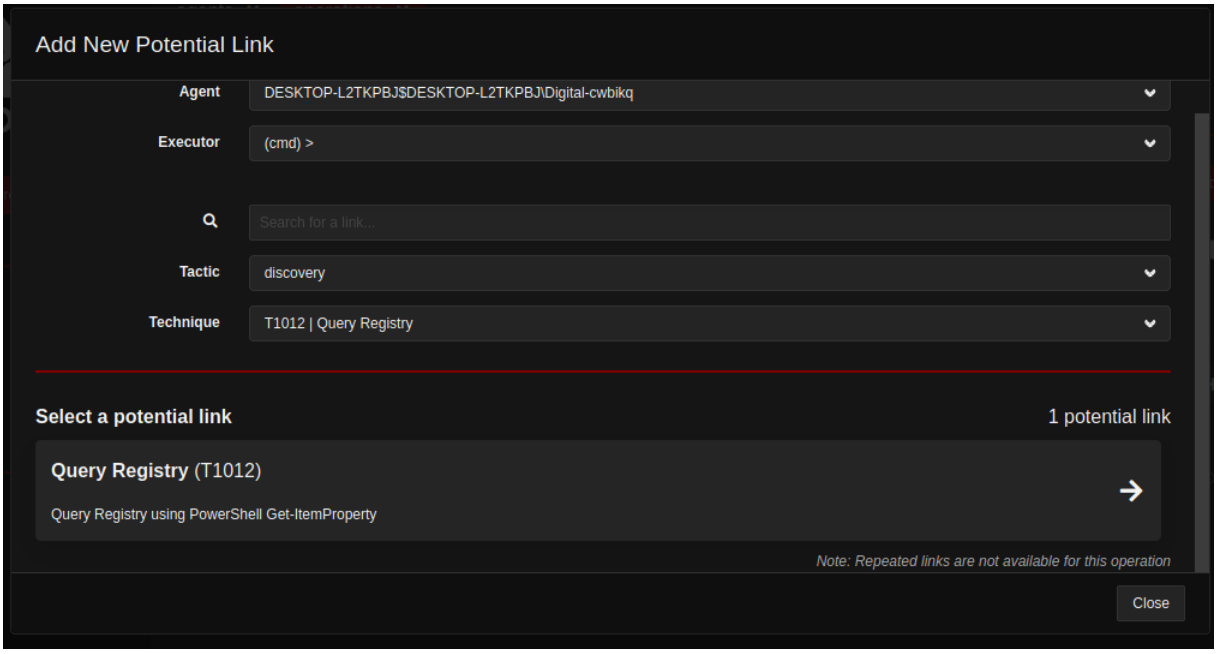




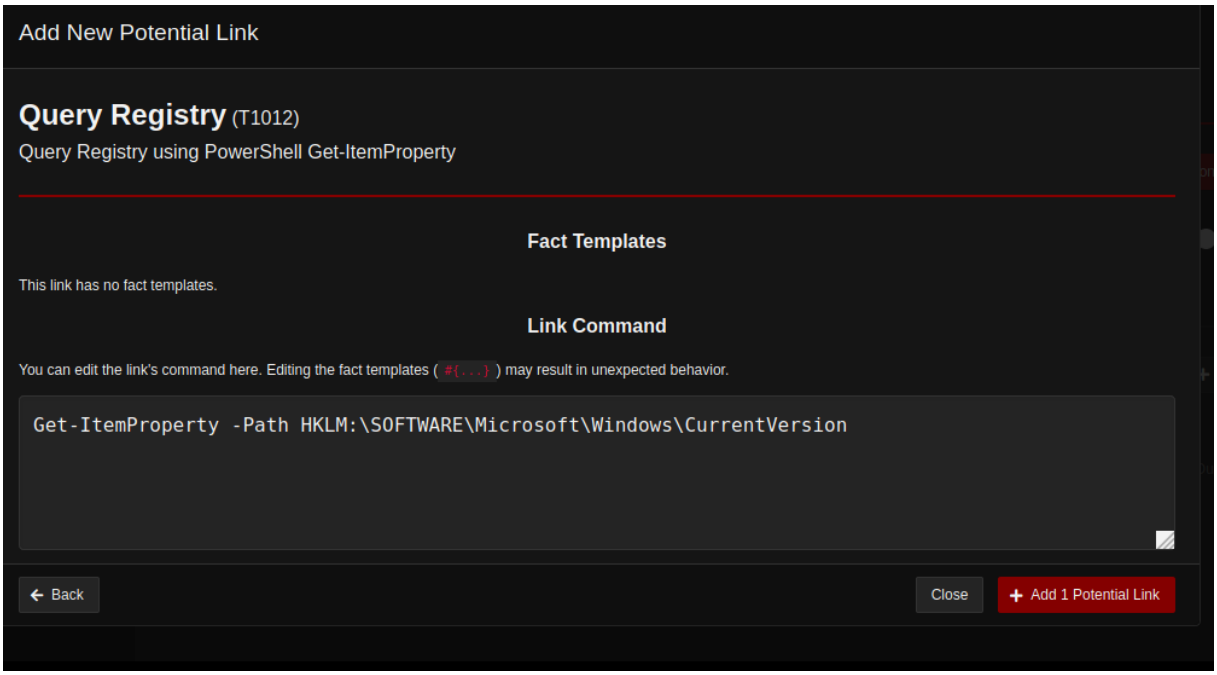
On choisit l'agent ainsi que l'exécuteur (**PowerShell** dans notre cas). Ensuite, on sélectionne la tactique souhaitée à l'aide de la liste déroulante, puis la technique correspondante. En fonction de nos choix, les commandes possibles sont alors proposées.



Dans notre cas, à des fins de test, nous choisissons les éléments présentés sur l'image ci-après afin d'illustrer le fonctionnement.

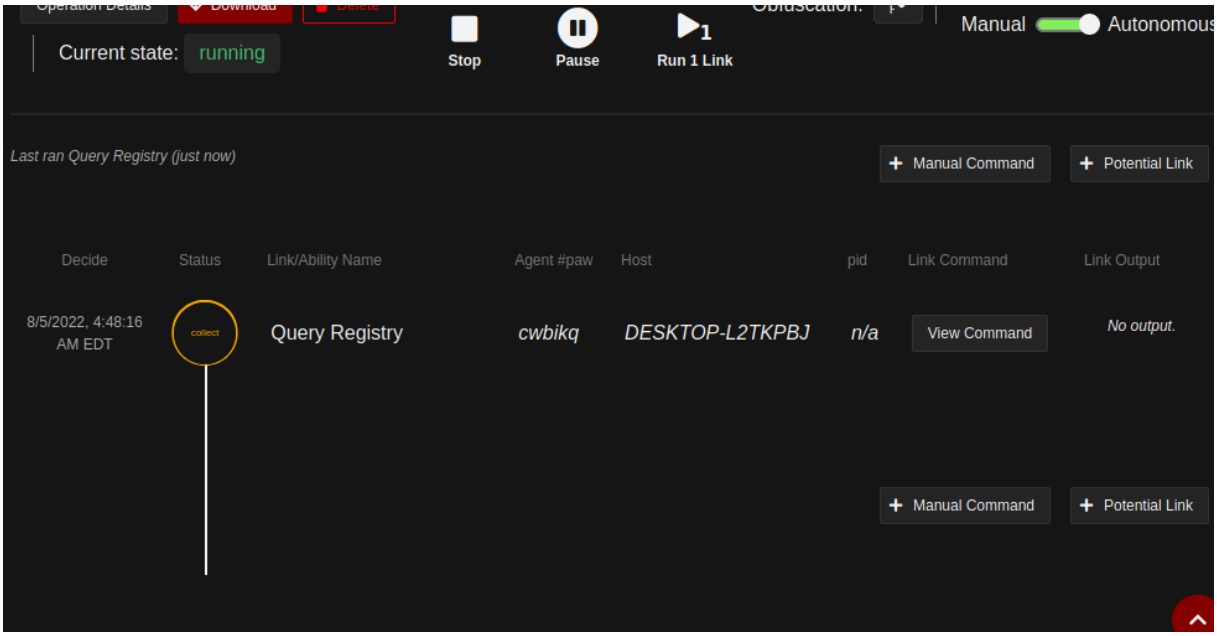


On sélectionne le lien, puis on accède à la page suivante. Celle-ci présente un résumé de la commande qui sera exécutée sur la machine cible.



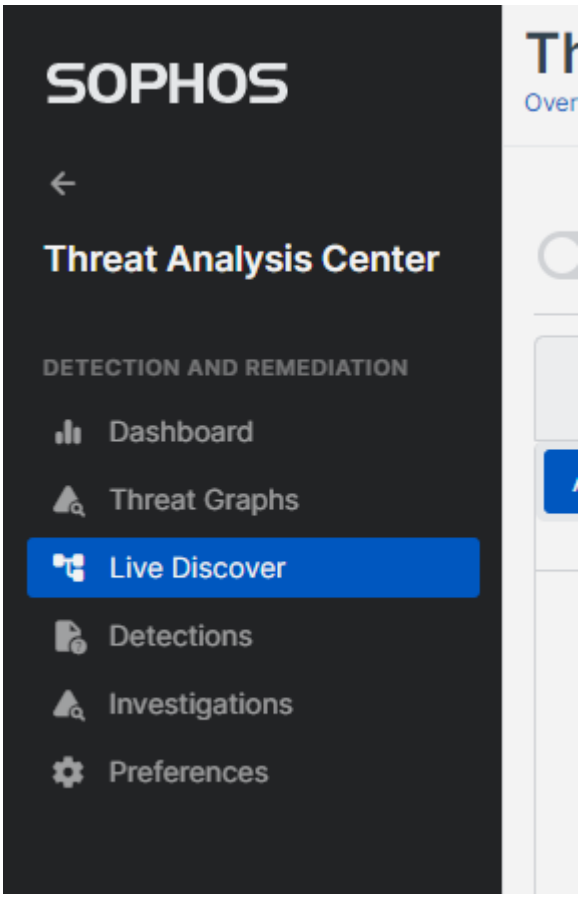
On clique sur le bouton rouge situé en bas, puis l'opération se lance comme on peut le voir sur l'image suivante.

Le statut apparaît en jaune, ce qui signifie que l'opération est en cours. Une fois terminée, le statut passe au vert.

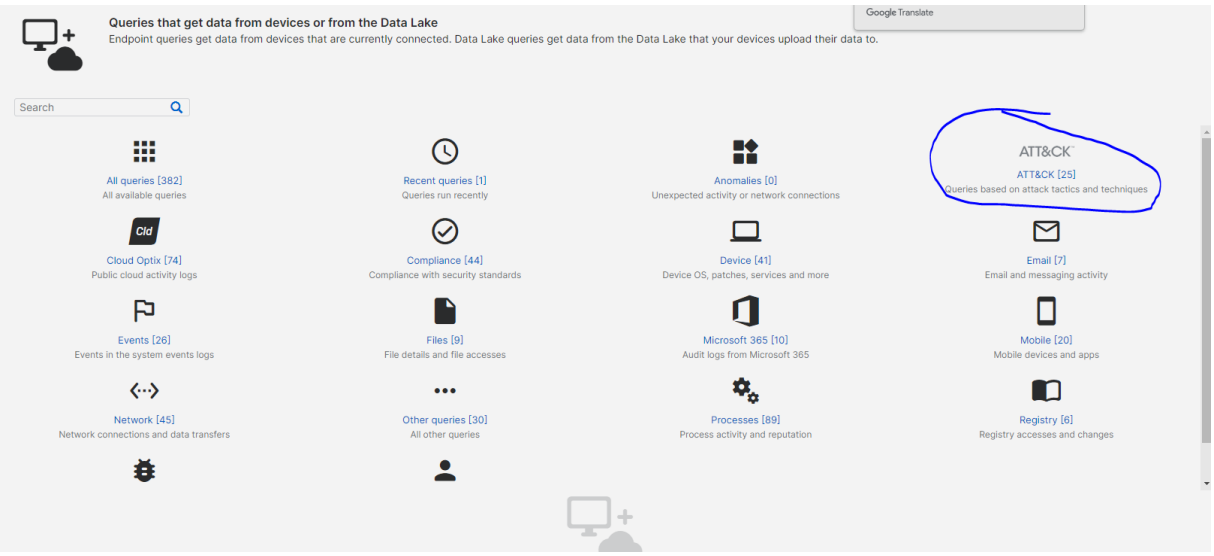


Nous allons répéter l'opération avec différentes techniques. Ensuite, on se rend sur le tableau de bord **Sophos** afin d'activer la détection. Nous utilisons **Live Detection** pour analyser ce qui se passe sur la machine cible.

Une fois connecté, on se dirige vers **Threat Analysis Center**, situé dans le menu, puis on sélectionne **Live Discover**.

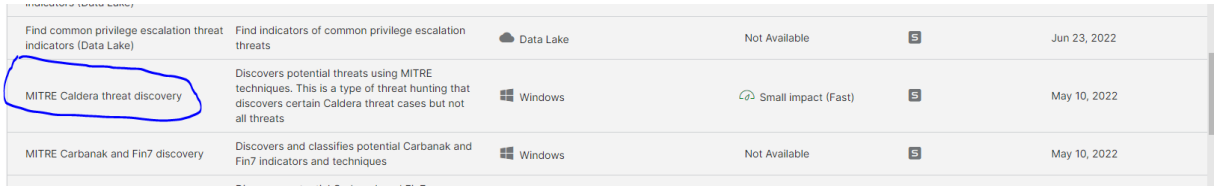


A droite on choisit ATT&CK comme encadré sur l'image.

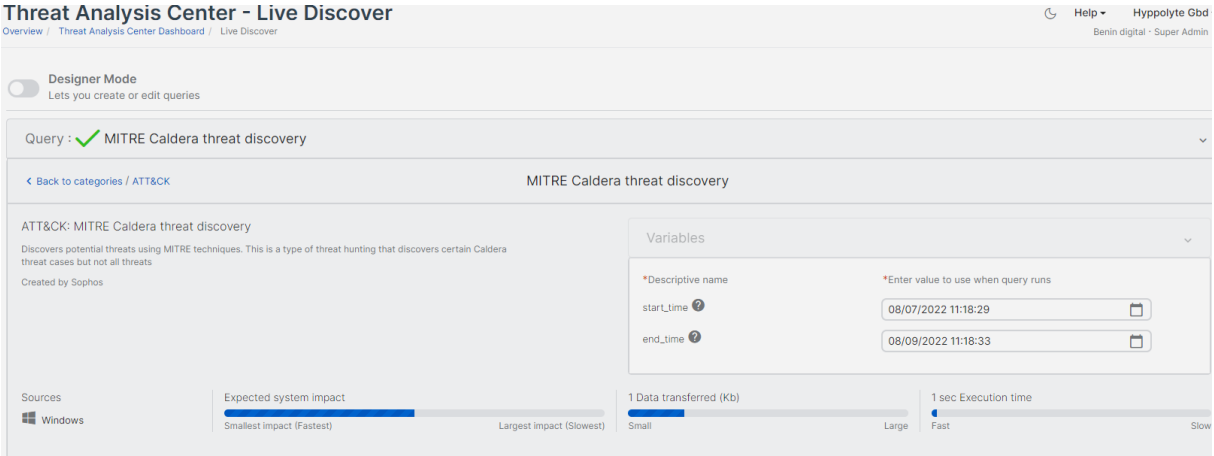


On accède à la page suivante, qui demande de renseigner certaines informations. Il faut alors faire un choix parmi les options proposées.

Un peu plus bas, on sélectionne **MITRE CALDERA**, comme indiqué sur l'image.

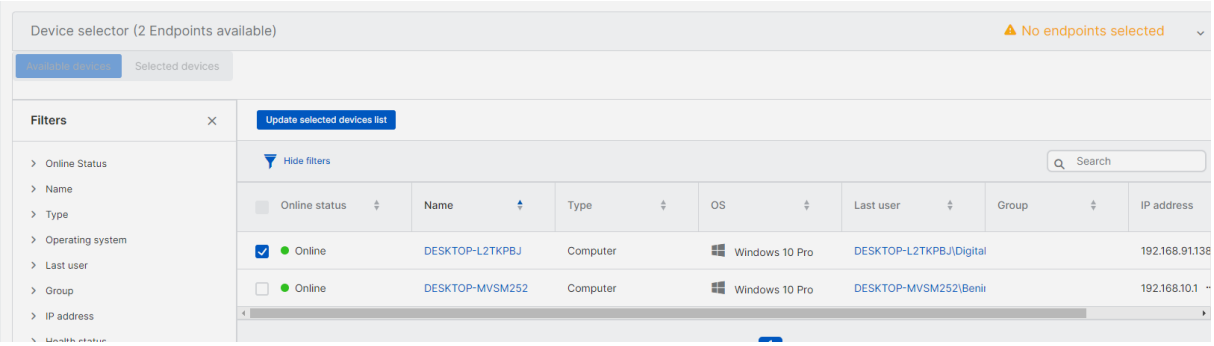


On nous demande de renseigner la date à laquelle doit s'exécuter la requête.

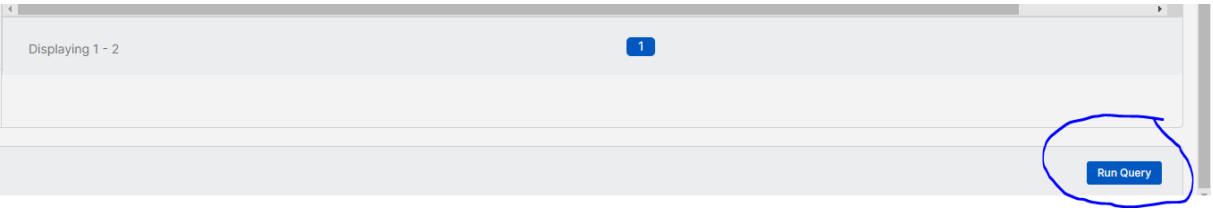


En bas, on sélectionne la machine sur laquelle on souhaite analyser les attaques ou les événements anormaux. Dans notre cas, il s'agit de la machine Windows utilisée pour les tests.

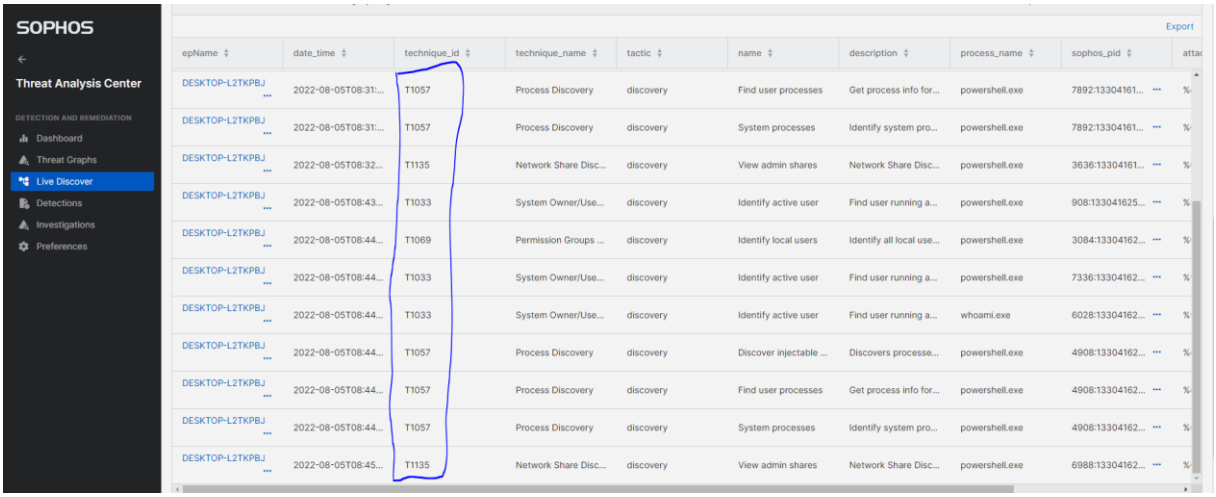
On clique ensuite sur le bouton bleu, situé en haut de la liste des ordinateurs, pour valider la sélection.



Cliquons ensuite **Run Query** pour lancer la découverte.



La découverte est lancée. Quelques secondes après on devrait obtenir tout ce qui se passe sur la machine cible. Comme sur l'image.



On constate sur l'image qu'une activité de récupération d'informations est en cours sur la machine, en utilisant la technique **Discovery**.

Sophos liste toutes les techniques utilisées, avec des informations détaillées telles que :

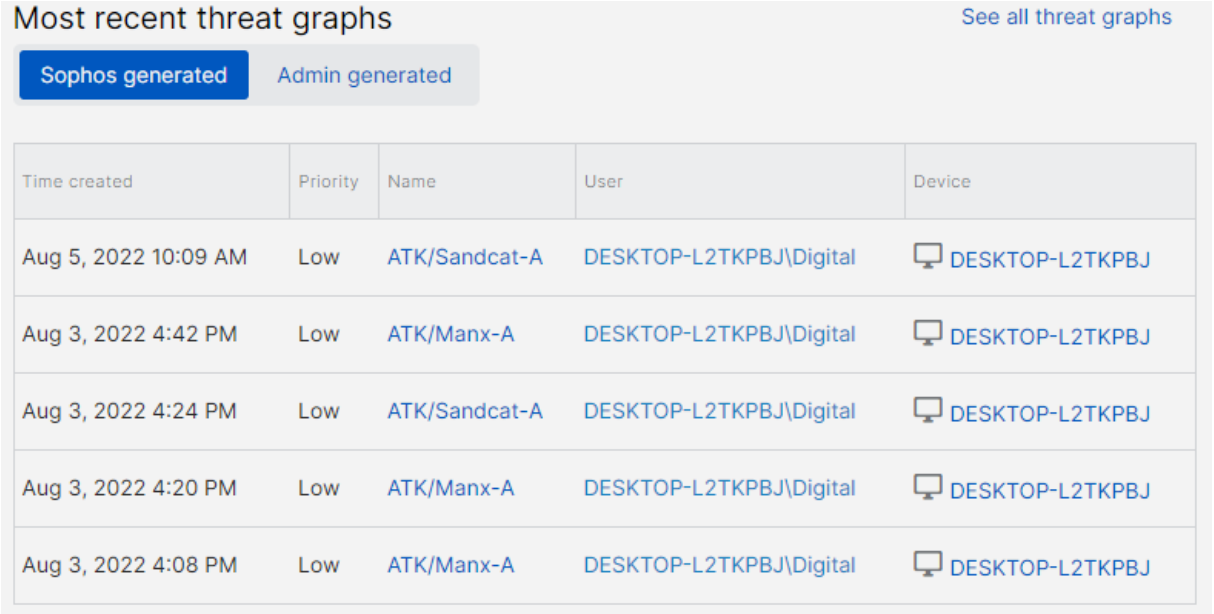
- l'ID de la technique
- le nom de la technique
- la tactique associée
- la description de l'activité
- le processus utilisé

Toutes ces informations permettent d'avoir une vision claire de ce qui se passe sur la machine cible. On peut ainsi prendre des mesures pour protéger le système.

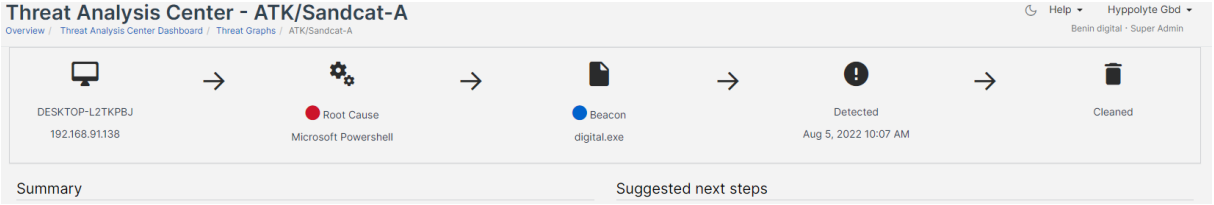
Avant cela, voyons comment Sophos synthétise ces informations. Lors de la simulation d'attaque, **CALDERA** exécute des actions en arrière-plan pouvant compromettre le système.

Rendons-nous dans le **"Dashboard"**, toujours dans le **"Threat Analysis Center"**, pour analyser ce qui s'est réellement passé.

On obtient un résultat similaire à celui présenté ci-dessous (le résultat peut varier selon votre environnement).

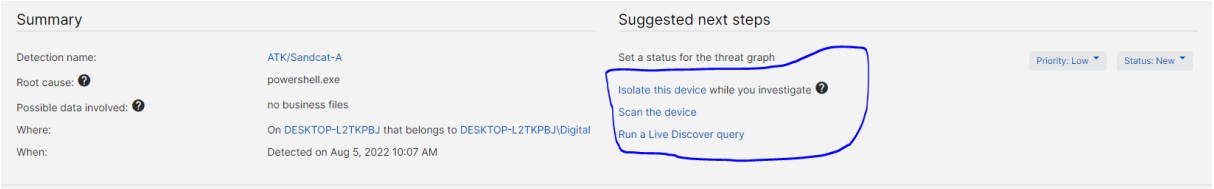


Cliquons sur le logiciel en question et analysons-le.

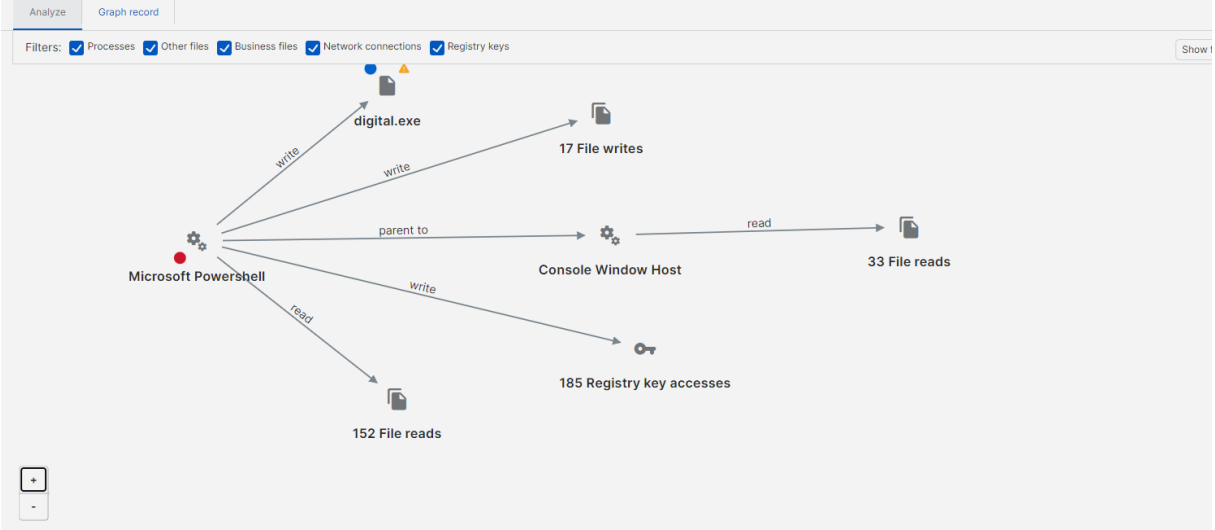


On constate que **Sophos** retrace le fonctionnement du logiciel détecté. Après détection, il le supprime automatiquement.

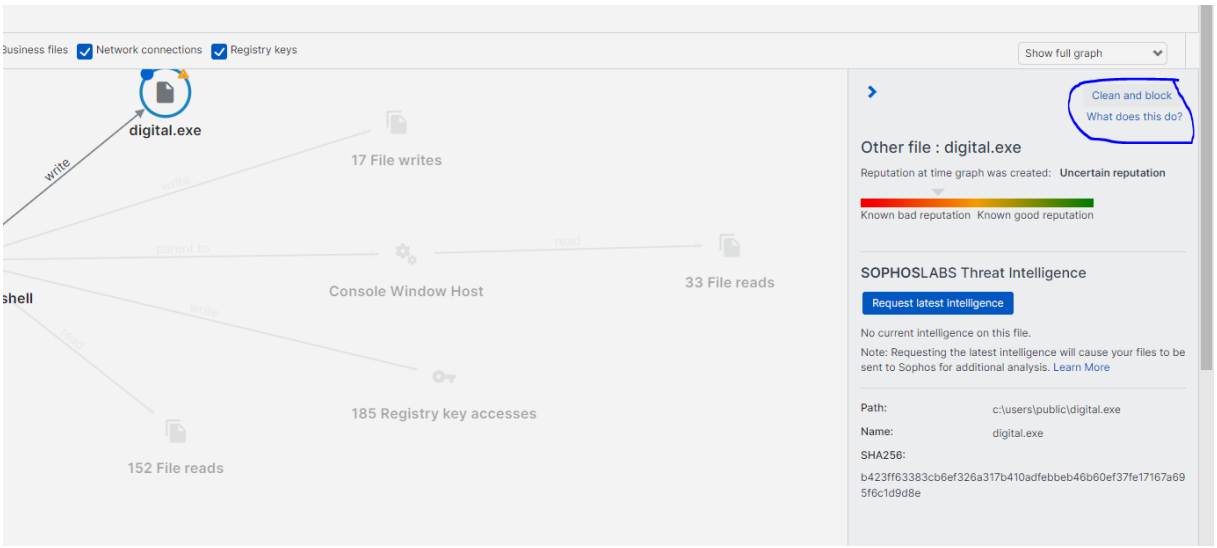
Sur la figure suivante, on retrouve un résumé du logiciel. À droite, **Sophos** propose plusieurs actions, comme isoler la machine, lancer un scan ou effectuer toute autre action visant à protéger le système.



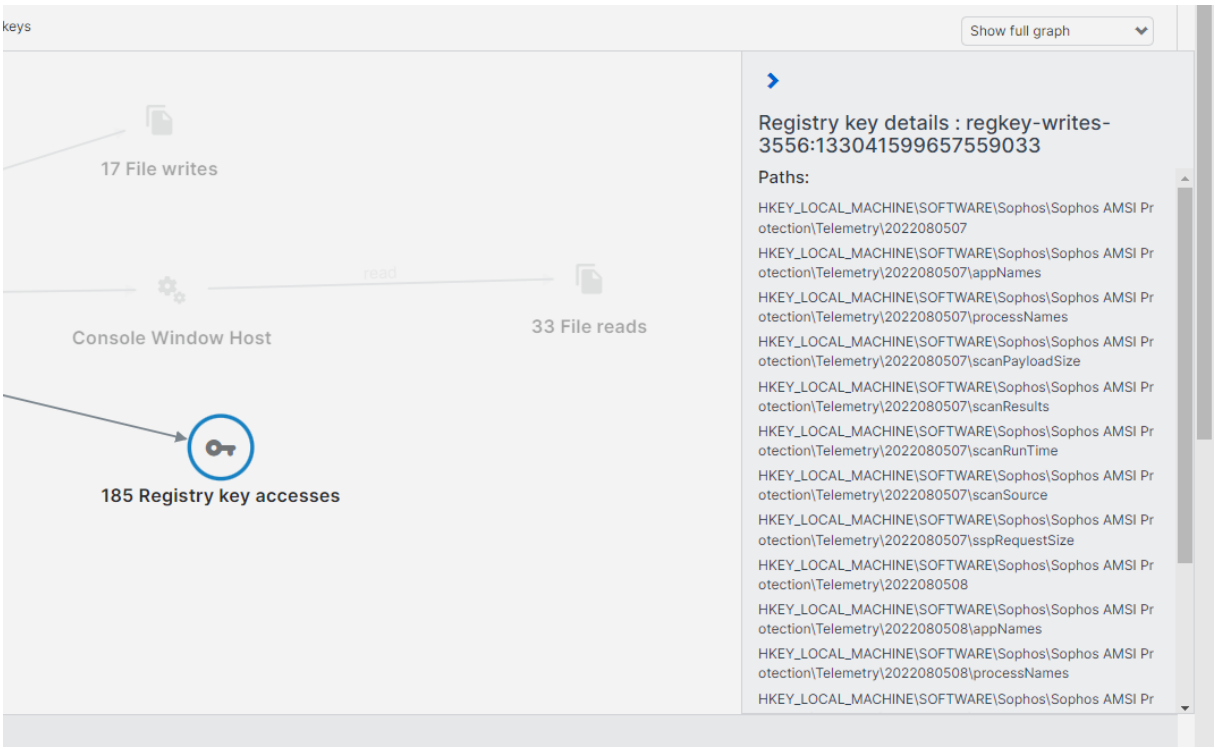
Sophos permet également de mieux comprendre les éléments impliqués dans l'exécution du logiciel, ainsi que les actions réalisées par chacun d'eux, à travers un graphe. On peut le constater sur l'image ci-après.



Nous cliquons sur **digitale.exe**, ce qui affiche toutes les informations le concernant. Nous avons également la possibilité de le supprimer et de nettoyer le système, comme on peut le voir sur l'image suivante.

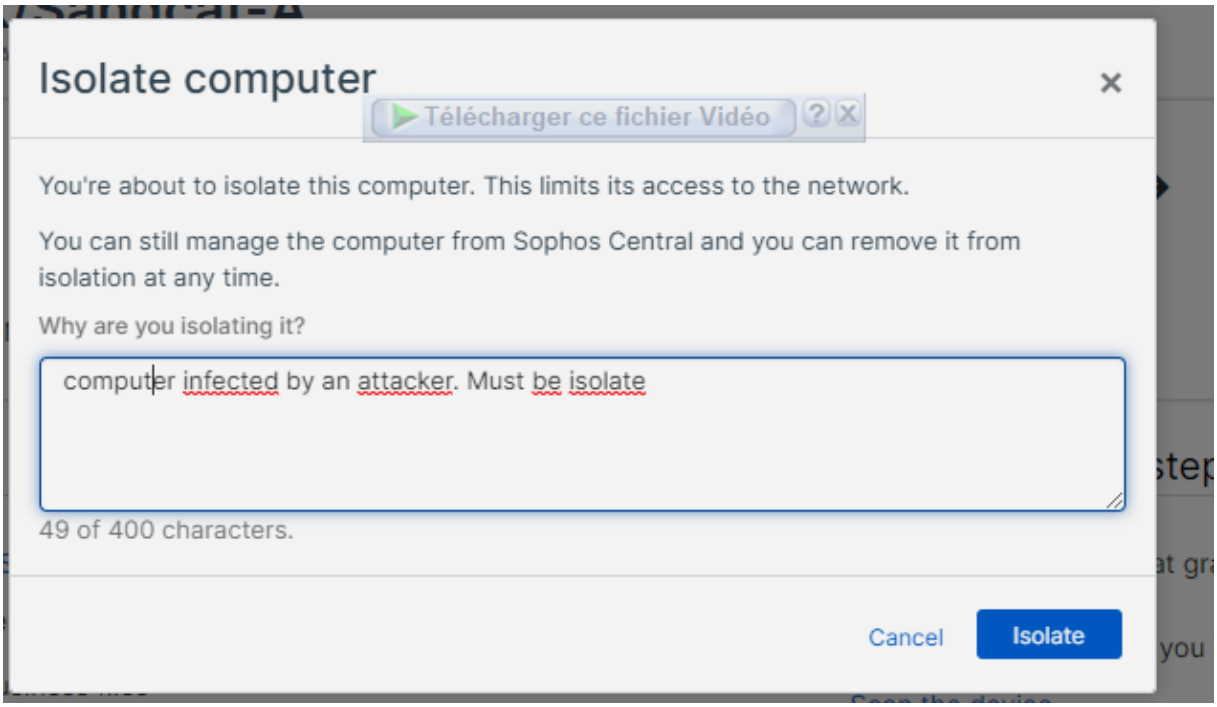


On peut tout comprendre avec ce graphe en cliquant sur chacun des éléments

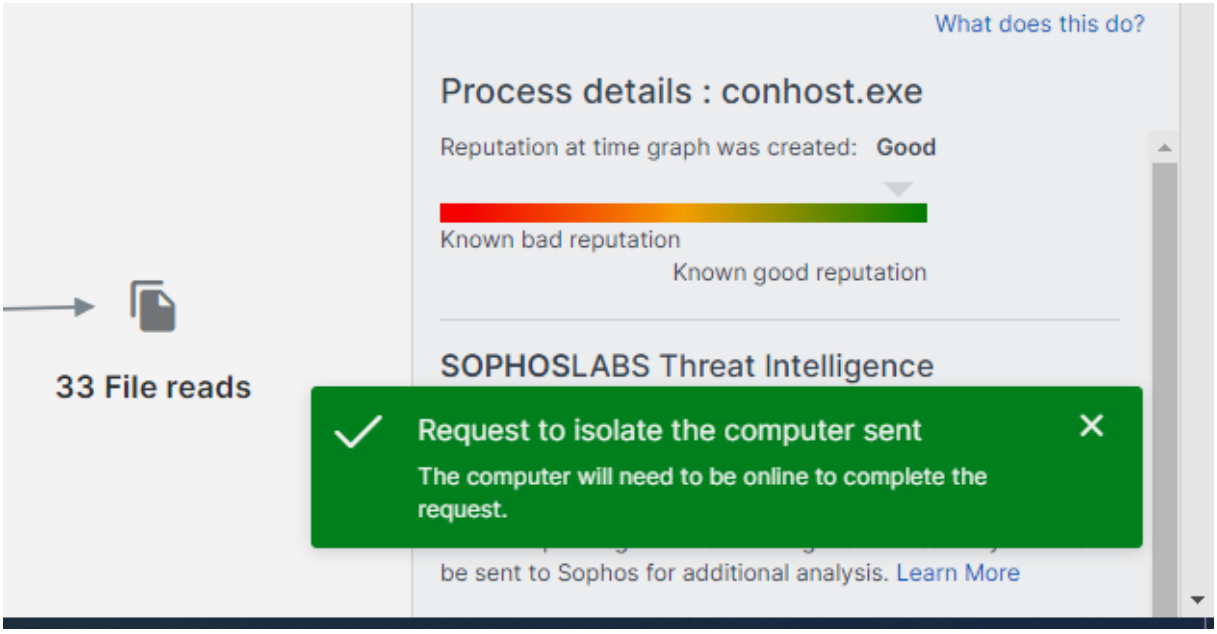


En tant qu'administrateur, une fois l'analyse et l'investigation terminées, on peut décider d'isoler la machine infectée et de poursuivre la gestion de l'incident.

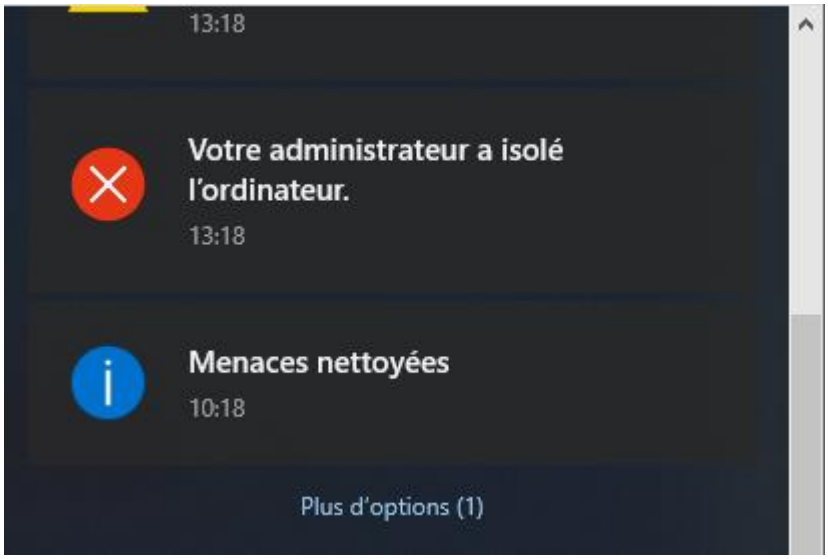
Lors de l'isolement, il est possible d'ajouter un message comme référence.



En cliquant sur **Isolate**, la requête est envoyée à l'ordinateur. On obtient ensuite la notification suivante



Sur la machine infectée, on reçoit la notification : Votre administrateur a isolé l'ordinateur.



On peut le confirmer au niveau de l'agent Sophos EDR déployé sur la machine

Voilà comment fonctionne **Sophos EDR**. Toutes les techniques testées avec **CALDERA** fonctionnent de manière similaire.

À travers ces différentes techniques et tactiques de **MITRE ATT&CK**, nous avons pu observer comment **Sophos** réagit face à des attaques simulées.